AEE. Bitácora III. Conexiones Empresariales
Taller Técnico: Operación Escudo

1. Fase Práctica: *Hardening* y Vigilancia en la Trinchera

Esta fase debe ser documentada paso a paso. En una auditoría real, no basta con mostrar el resultado final; el "cómo se llegó ahí", las decisiones tomadas y los comandos ejecutados son la verdadera evidencia de vuestra competencia técnica.

Reto A: Auditoría de Accesos e Intrusiones (Log Analysis y Scripting)

El archivo de registro de autenticación es vuestra "caja negra". Si alguien intenta forzar la entrada utilizando técnicas de *Fuerza Bruta* o *Ataques de Diccionario*, el rastro indeleble quedará grabado aquí.

1. **Generación de ataques controlados**. Desde vuestro equipo host (Windows) o desde una segunda máquina virtual, realiza al menos 5 intentos fallidos de conexión SSH contra vuestro servidor (ej: ejecutando *ssh administrador_falso@ip_del_servidor* y metiendo contraseñas inventadas).

usuario_falso@192.168.20.174

```
:\Users\DAW1>ssh adminfalso@192.168.20.174
The authenticity of host '192.168.20.174 (192.168.20.174)' can't be establish
ED25519 key fingerprint is SHA256:yrFUECr5gk0m11YNoMGs7DOAveQEDHDOM771SF5MyYQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.20.174' (ED25519) to the list of known ho
adminfalso@192.168.20.174's password:
Permission denied, please try again.
adminfalso@192.168.20.174's password:
Permission denied, please try again.
adminfalso@192.168.20.174's password:
adminfalso@192.168.20.174: Permission denied (publickey,password).

:\Users\DAW1>ssh adminfalso@192.168.20.174
adminfalso@192.168.20.174's password:
Permission denied, please try again.
adminfalso@192.168.20.174's password:
Permission denied, please try again.
adminfalso@192.168.20.174's password:
adminfalso@192.168.20.174: Permission denied (publickey,password).
```

2. **Análisis Forense Manual**. Accede a */var/log/auth.log* utilizando herramientas de visualización rápida como *tail -n 50*, *less* o filtrando con *grep*. Debéis ser capaces de identificar y hacer una captura de pantalla donde se vea claramente: la dirección IP de origen del atacante, el puerto efímero utilizado y el mensaje literal de error del sistema (algo parecido a *Failed password for invalid user...*).

grep failed password /var/log/auth.log

3. **Automatización inteligente con Bash**. Como imaginaréis, un administrador no puede pasarse la mañana leyendo miles de líneas de texto plano. Debéis crear un *script* en *bash* en la ruta *scripts/check_intruders.sh* que automatice esta tarea. El script debe:
    - Filtrar exclusivamente los intentos fallidos de conexión de las últimas horas. *Pista*: Herramientas como *grep*, *awk* o *sed* serán vuestras mejores amigas para extraer columnas de texto.
    - Contar matemáticamente el número total de errores detectados.
    - Generar (o sobrescribir) un archivo de reporte limpio llamado **alertas.txt** que incluya un encabezado con la fecha y hora exacta de la generación del informe.
    - Requisito de calidad. El script no puede ser un bloque de código incomprensible. Debe estar **debidamente documentado** mediante **comentarios (#)** explicando qué hace exactamente cada variable, tubería (|) y comando utilizado.

Reto B: Configuración del "Escudo" Perimetral con UFW

Bajo el capó de Ubuntu trabaja el potente motor de filtrado de paquetes *iptables* (o *nftables*). Sin embargo, nosotros utilizaremos **UFW (Uncomplicated Firewall)**, una interfaz amigable que nos facilita la vida. Vamos a aplicar la arquitectura más segura: una política de "Denegación por Defecto". Todo lo que no esté explícitamente invitado a entrar, se quedará fuera.

1. **Reglas de Sigilo** (*Drop* vs *Reject*). Configura el firewall para que el servidor ignore completamente las peticiones ICMP Echo Request (el famoso comando ping). Un servidor que hace drop (dejar caer el paquete sin responder) a los pings, se vuelve prácticamente invisible frente a los escaneos de red superficiales que buscan hosts vivos.
2. **Reglas de Servicio**. Por otro lado, si bloqueamos todo, nosotros tampoco podremos administrarlo. Permitid el acceso TCP exclusivamente al puerto 22 (SSH). Si, como buena práctica, habéis cambiado el puerto SSH por defecto a uno superior, aseguraos de abrir ese puerto específico.
3. **Activación y Evidencias**. Ejecuta *sudo ufw enable*. Posteriormente, verifica el estado y la carga real de las reglas con los comandos *sudo ufw status numbered* y *sudo ufw status verbose*.
4. **Prueba cruzada**. En vuestra documentación, debéis incluir capturas demostrando que desde la máquina anfitriona el *ping* da error de tiempo de espera, pero la conexión por cliente SSH (como Windows PowerShell o el Terminal) sí se establece correctamente.

4. Rúbrica de Evaluación Detallada y Feedback

Para que no haya sorpresas, la calificación de esta sesión se otorgará estrictamente en base al cumplimiento de los criterios descritos en la siguiente matriz. Además, durante los últimos 15 minutos de la clase, realizaremos una rápida inspección cruzada (Peer Review) donde comprobaréis la robustez del servidor de vuestro compañero de mesa.

Criterio	Excelente (9-10)	Bien (7-8)	Suficiente (5-6)	Insuficiente (0-4)
Investigación y Referencias (IEEE)	Cita fuentes académicas de gran impacto. Explica la arquitectura Syslog y las implicaciones legales del Log Management con una profundidad analítica sobresaliente. Formato IEEE perfecto.	Cita fuentes válidas pero la explicación peca de ser algo superficial o puramente descriptiva. Puede haber algún error menor de puntuación en el formato de cita.	La investigación es muy básica o divagante. Las citas provienen de foros o blogs sin autoridad, están incompletas o ignoran totalmente el estándar IEEE.	No existe investigación previa. Es un plagio directo de fuentes externas, “copia/pega” desde IA o se omiten las referencias bibliográficas.
Configuración Técnica UFW (RA6)	UFW activo con política de denegación, bloqueo total de ICMP y SSH permitido. Demuestra el éxito con pruebas cruzadas impecables y capturas de pantalla nítidas.	UFW activo y funcional, pero falta la regla específica de bloqueo de ICMP o las evidencias visuales de la prueba de verificación son confusas o incompletas.	El firewall funciona a nivel básico, pero no se han configurado las reglas de sigilo requeridas o el servicio SSH no responde adecuadamente.	Configuración errónea que deja el sistema vulnerable, o peor, bloquea el propio acceso del administrador perdiendo el control del servidor.
Automatización / Scripting Bash (RA6)	Script robusto, elegante e idempotente. Utiliza variables, procesa texto con agilidad y genera alertas.txt con un formato profesional. Documentación interna línea a línea excelente.	Script funcional que cumple el objetivo principal, pero carece de algunos comentarios explicativos o el formato de salida en el archivo de texto es algo desordenado o difícil de leer.	El script realiza la tarea a duras penas, presenta errores sintácticos menores, usa enfoques muy ineficientes o la lógica de filtrado es imprecisa.	El script no es ejecutable (falta de permisos chmod +x), tiene errores lógicos fatales o directamente no se incluye en la entrega.

Criterio	Excelente (9-10)	Bien (7-8)	Suficiente (5-6)	Insuficiente (0-4)
Calidad Documental (GitHub/MD)	Repositorio impecablemente estructurado (directorios lógicos como /scripts, /docs). README profesional con índices, fragmentos de código, capturas insertadas y narrativa clara.	README completo pero con una estructura visual mejorable. Las capturas están presentes pero carecen del pie de foto o la descripción técnica de lo que se está observando.	Repositorio desorganizado. Falta información relevante, uso pobre de la sintaxis Markdown o las evidencias visuales no demuestran fehacientemente el trabajo realizado.	El enlace proporcionado a GitHub es privado o erróneo. Repositorio vacío, subida de archivos sueltos sin README o documentación inexistente.

Referencias para la consulta

[1] W. Acosta Lugo, *Guía de uso de BBDD Académicas para Ciclos Formativos*, Sevilla, España: Departamento de Informática, 2026. Disponible en: https://drive.google.com/file/d/1Zg4LNDAs55OgEK1gmqbGx8NZyc1CdJjM/view?usp=sharing.

[2] IEEE, *IEEE Editorial Style Manual for Authors*, IEEE Periodicals, 2023. [En línea]. Disponible en: https://journals.ieeeauthorcenter.ieee.org/your-role-in-article-production/ieee-editorial-style-manual/

[3] Canonical Ltd., "Ubuntu Server documentation," Ubuntu Documentation, 2025. [En línea]. Disponible en: https://ubuntu.com/server/docs/explanation/intro-to/security/

[4] M. B. Alonso Alegre Díez, "Gestión de Logs," Trabajo Fin de Máster, Universidad Internacional de La Rioja (UNIR), 2016. [En línea]. Disponible en: https://reunir.unir.net/bitstream/handle/123456789/3618/ALONSO-ALEGRE%20DIEZ%2C%20MARIA%20BEGO%C3%91A.pdf

[5] S. McClure, J. Scambray y G. Kurtz, *Hacking Exposed: Network Security Secrets & Solutions*, 3ª ed. Nueva York, NY, EE. UU.: McGraw-Hill Education, 2001. Disponible en: https://github.com/jwx0539/hackingLibrary/blob/master/McGraw.Hill.Hacking.Exposed.Network.Security.Secrets.And.Solutions.3rd.Edition.Sep.2001.ISBN.0072193816.pdf